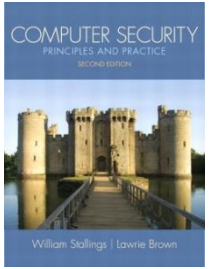
אבטחת סייבר

(אבטחת מערכות מידע/מחשבים/מערכות ממוחשבות/...)



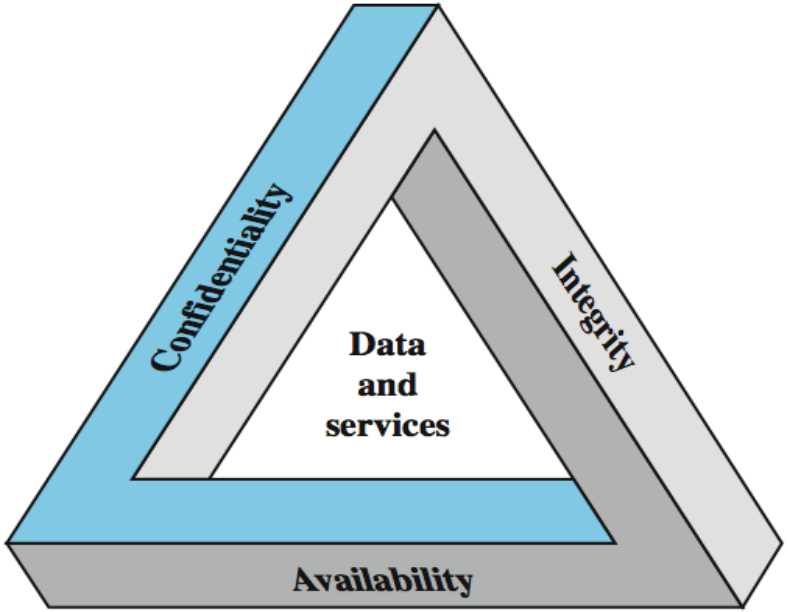
המצגת הינה לשימוש פנימי בלבד

אין לצלם או לעשות שימוש שלא במסגרת הקורס

נושאי הקורס

- סכנות ושיטות הגנה
- מודלים ומדיניות
- הצפנה ופרוטוקולים
- אימות זיהוי
- בקרת גישה
- הגנה בחומרה ובמערכות הפעלה
- הגנה בבסיסי נתונים
- וירוסים, תולעים, ודומיהם
- תכנות בטוח
- הגנה ברשתות תקשורת וב-WWW
- ועוד, ככל שירשה לנו הזמן

Key Security Concepts



Computer Security Challenges

1. not simple
2. must consider potential attacks
3. procedures used counter-intuitive
4. involve algorithms and secret info
5. must decide where to deploy mechanisms
6. battle of wits between attacker / admin
7. not perceived on benefit until fails
8. requires regular monitoring
9. too often an after-thought
10. regarded as impediment to using system

Some common terms

- Vulnerability
- Threat
- Threat vs. Vulnerability (or Being Vulnerable to the Threat of Confusing Threats with Vulnerabilities)
  - Threat: Adversaries might **install malware** in the computers in our Personnel Department so they can **steal** social security numbers for purposes of **identity theft**
  - Vulnerability: The computers in the Personnel Department do not have up to date virus definitions for their anti-malware software

Some common terms

- Attack: An attempt by an adversary to cause harm to valuable assets
- Attack vector: a path or means of an adversary to enable them to exploit system vulnerabilities (including the human element).
  - e.g. viruses, e-mail attachments, deception, …
- Threat model – usually means what threats or attacks we protect against

Vulnerabilities and Attacks

- **system resource with vulnerabilities may**
  - be corrupted (loss of integrity)
  - become leaky (loss of confidentiality)
  - become unavailable (loss of availability)
- **attacks are threats carried out and may be**
  - passive
  - active
  - insider
  - outsider
  - warfare / espionage / etc.–

Methods of Attacks

Bypassing authentication
(e.g. guessing password)

Using Authority dishonestly
(e.g. System people)

Utilizing human error or carelessness

Utilizing “holes” in Software

Bypassing access control

Using Viruses

Use Inference from authorized access

Defense vs. Offense

- Attackers need to succeed only once
- Defenders must succeed every time!

BUT

- Attackers must pass through a chain of defenses
- Defenders only need to succeed in one link!

Major threats

- Stolen passwords
- Malware\Spyware
- Phishing
- Social Engineering
- DDOS
- Rogue SSL certificates
- Web exploiting (SQL injection, XSS,…)
- …

הצפנה

- דיברנו על "פרימיטיבים" של הצפנה ואימות – אבני בניין שישמשו אותנו לפי הצורך
  - הצפנה סימטרית/אסימטרית (AES,RSA)
  - אימות הודעות (MAC, חתימה דיגיטלית)
  - החלפת מפתחות (תעודות, DHE)

תזכורת

מפתח פומבי

- ידע שונה – בעל המפתח יודע יותר
- מפתח פומבי
- מפתח פרטי
- מבוססים על בעיות מתמטיות קשות

פרימיטיבים סימטריים

- ידע זהה לשני המשתתפים
- מפתח משותף
- או ללא מפתח
- מבוססים על מבנה שנראה קשה

עקרון קרכהופס

- צופן ידוע לכל
- מפתח סודי

צופן	
$C=E_K(M)$	$M=D_K(C)$

אופני תפעול

- ECB
- CBC
- CFB
- OFB
- CTR

תזכורת

פרימיטיבים סימטריים

- ידע זהה לשני המשתתפים
- מפתח משותף
- או ללא מפתח
- מבוססים על מבנה שנראה קשה

מפתח פומבי

- ידע שונה – בעל המפתח יודע יותר
- מפתח פומבי
- מפתח פרטי
- מבוססים על בעיות מתמטיות קשות

צפנים	מהירות	הנחות	ניהול מפתחות
סימטריים	✓ מהירים	הנחות אד-הוק	מסובך
אסימטריים	איטיים	בעיות מתמטיות קשות	✓ פשוט יותר

החלפת מפתחות אסימטרית

הצפנה סימטרית

תזכורת

פרימיטיבים סימטריים

- ידע זהה לשני המשתתפים
- מפתח משותף
- או ללא מפתח
- מבוססים על מבנה שנראה קשה

מפתח פומבי

- ידע שונה – בעל המפתח יודע יותר
- מפתח פומבי
- מפתח פרטי
- מבוססים על בעיות מתמטיות קשות

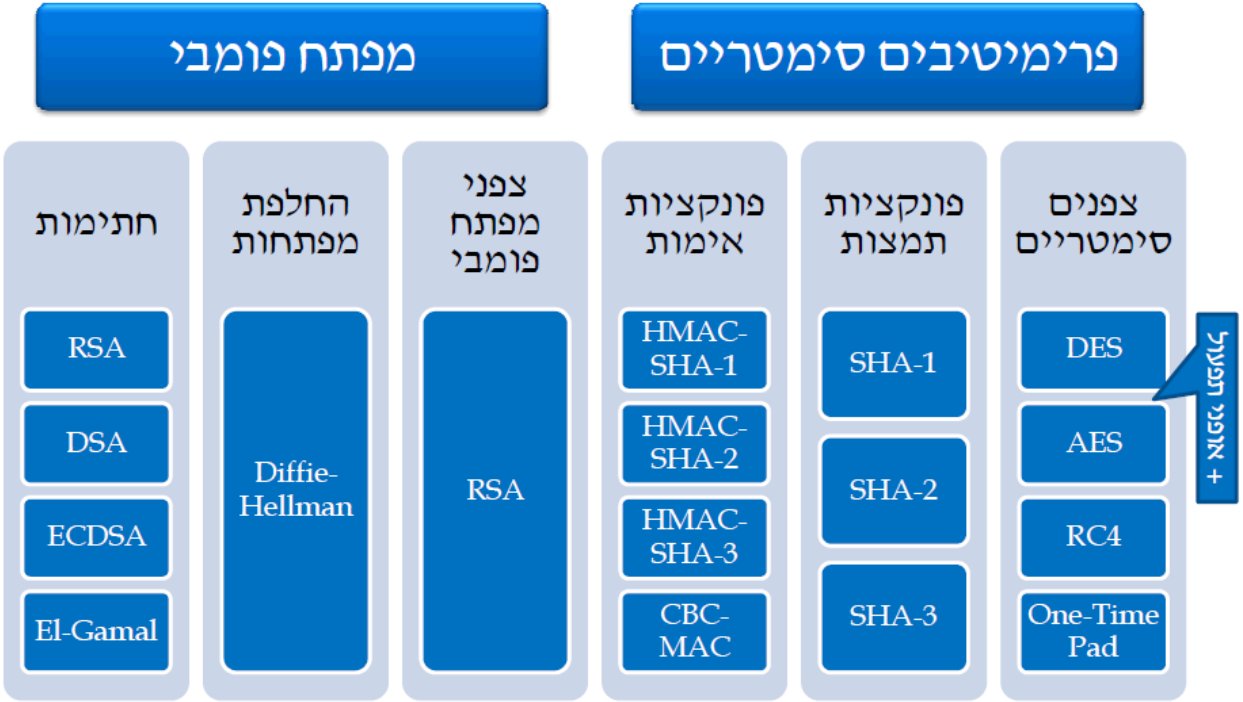
צפנים	מהירות	הנחות	ניהול מפתחות
סימטריים	✓ מהירים	הנחות אד-הוק	מסובך
אסימטריים	איטיים	בעיות מתמטיות קשות	✓ פשוט יותר

החלפת מפתחות אסימטרית

הצפנה סימטרית

	אימות השולח	שלמות	אי-הכחשה
חתימות דיגיטליות	☑	☑	☑
פונקציות אימות	☑	☑	×

תזכורת


מפתח פומבי
פרימיטיבים סימטריים
חתימות
RSA
DSA
ECDSA
El-Gamal
החלפת מפתחות
Diffie-Hellman
צפני מפתח פומבי
RSA
פונקציות אימות
HMAC-SHA-1
HMAC-SHA-2
HMAC-SHA-3
CBC-MAC
פונקציות תמצות
SHA-1
SHA-2
SHA-3
צפנים סימטריים
DES
AES
RC4
One-Time Pad
+ אלגוריתם

User Authentication

Something you know

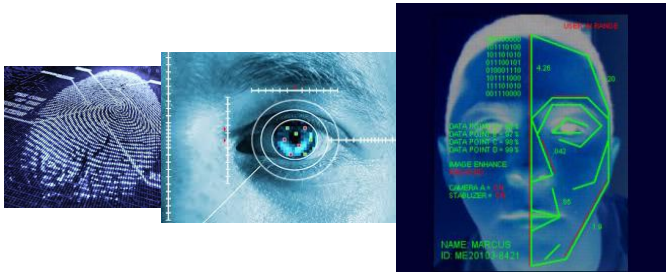
- password, PIN, answers to prearranged questions

Something you have

- smartcard, electronic keycard, physical key

Something you are (static)

- Fingerprint, retina, face



Something you do (dynamic)

- voice pattern, handwriting, typing rhythm (ABV- Activity-based Verification)

can use alone or combined
(multi factor authentication)
all can provide user authentication
all have issues

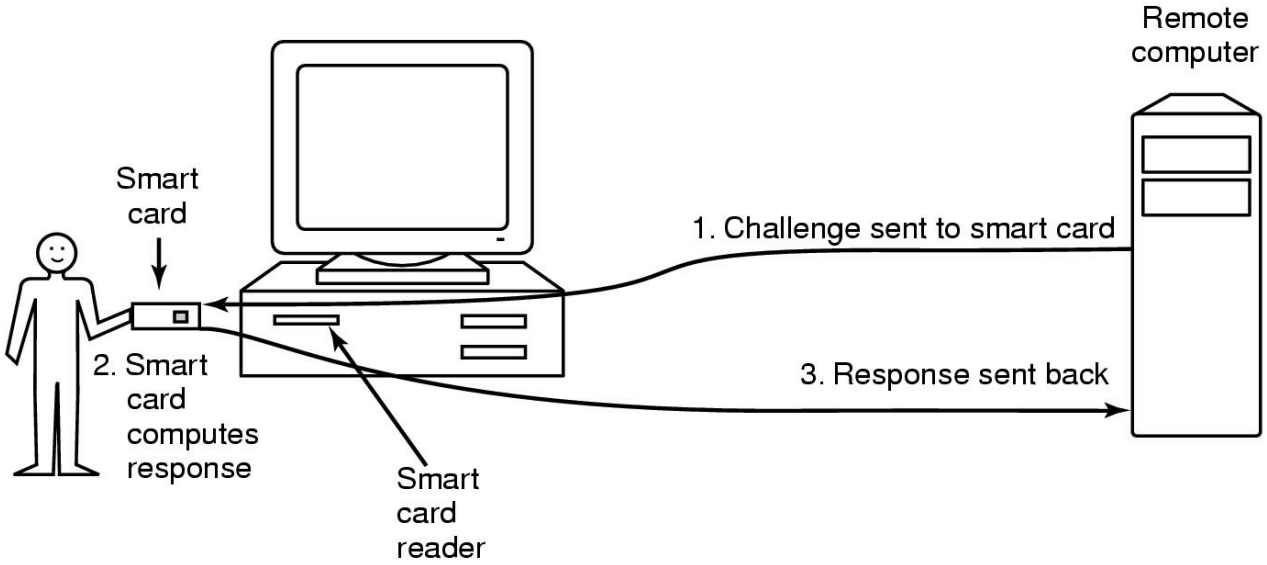
Authentication Using Passwords

Bobbie, 4238, e(Dog4238)
Tony, 2918, e(6%%TaeFF2918)
Laura, 6902, e(Shakespeare6902)
Mark, 1694, e(XaB@Bwcz1694)
Deborah, 1092, e(LordByron,1092)

Salt Password

The use of salt to defeat pre-computation of encrypted passwords

Authentication Using a Physical Object



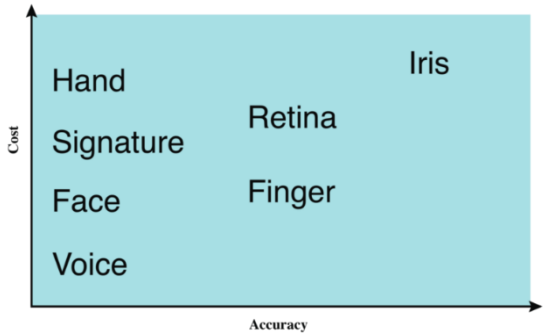
Magnetic cards

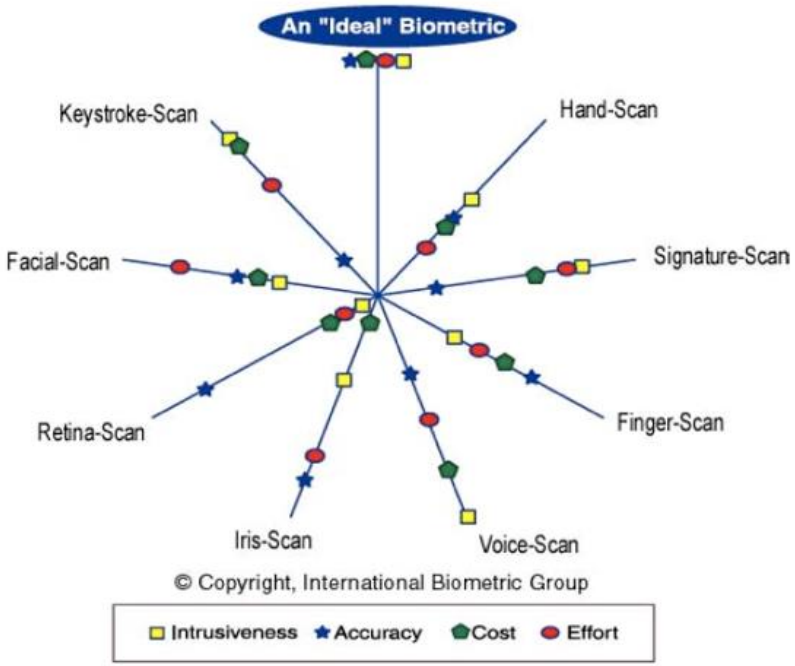
magnetic stripe cards

chip cards: stored value cards, smart cards

Biometrics - parameters to consider

- Accuracy
- Intrusiveness
- Cost
- Time to process

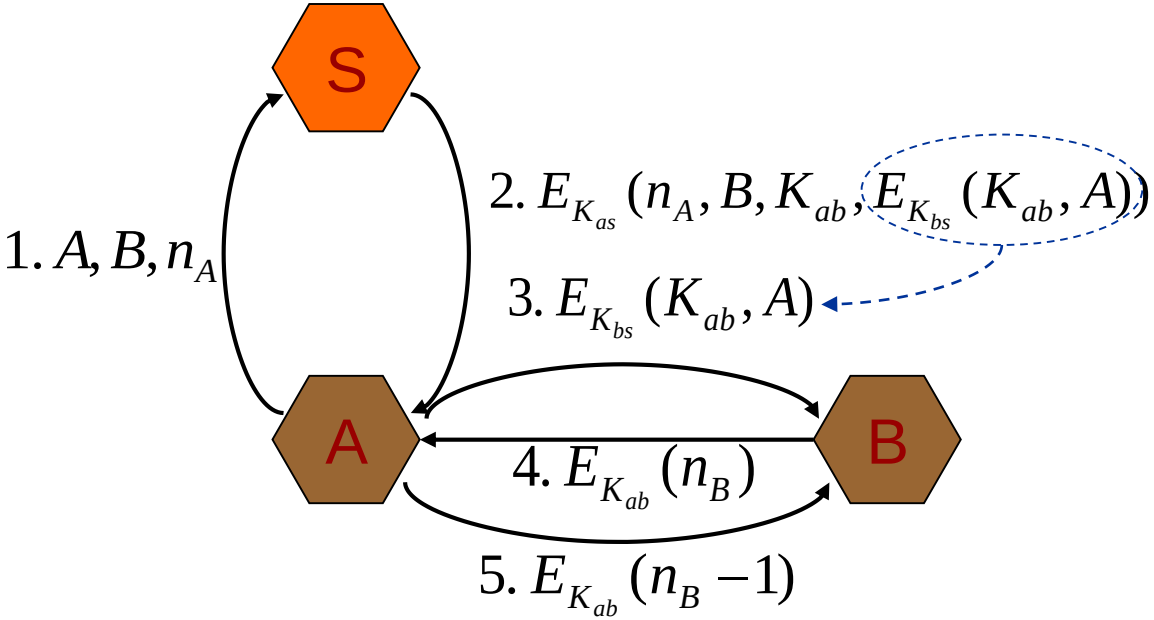




Source: Zephyr Analysis

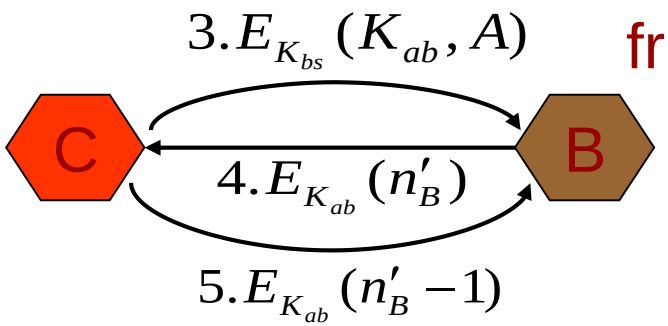
Passwords: Text vs Graphical

Needham-Schroeder Protocol



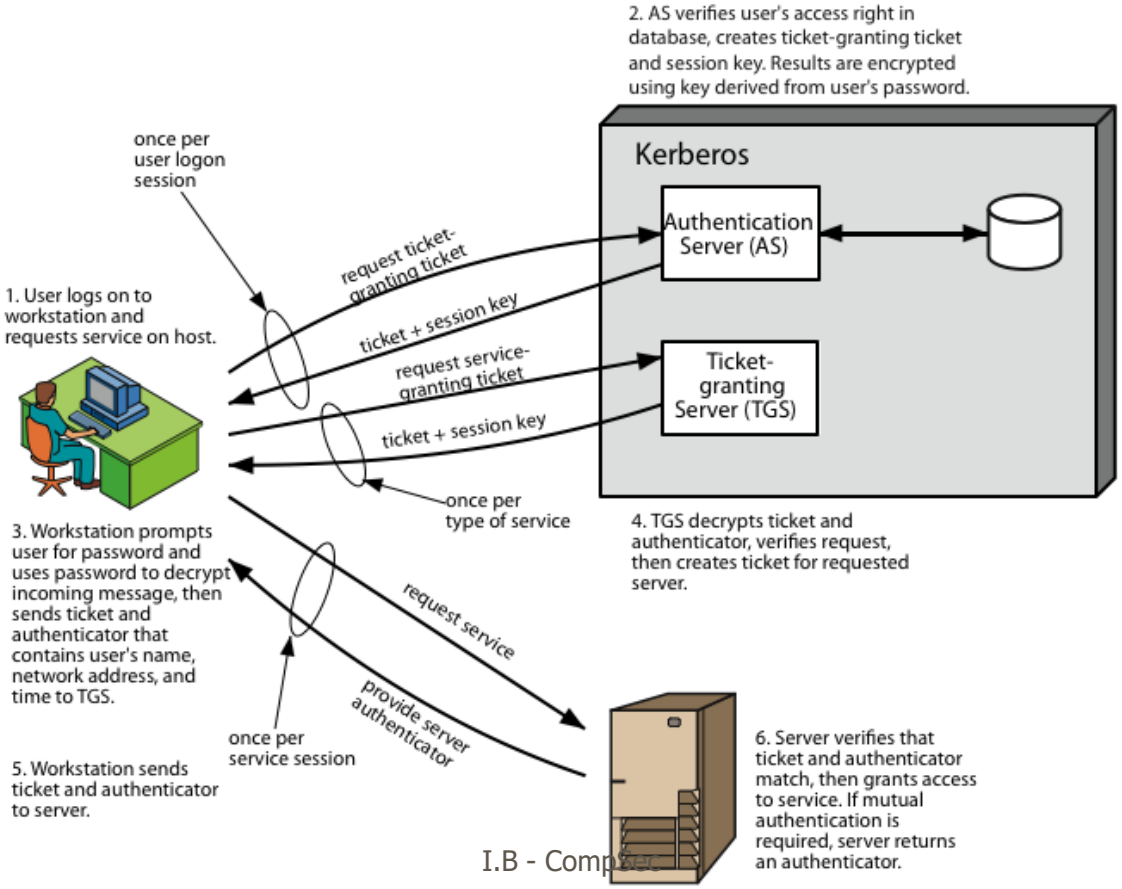
Denning-Sacco Attack

- The NS protocol achieves its goals under the (standard) assumption that the long term keys K_{as} and K_{bs} are not compromised.
- Denning & Sacco discovered an attack where the adversary *C* impersonates *A* re-using a compromised session key K_{ab}:

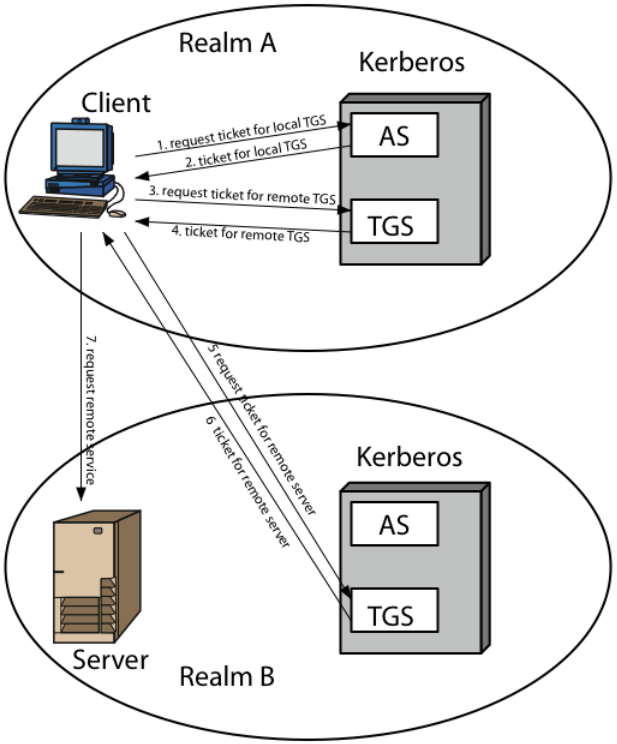


from original protocol run

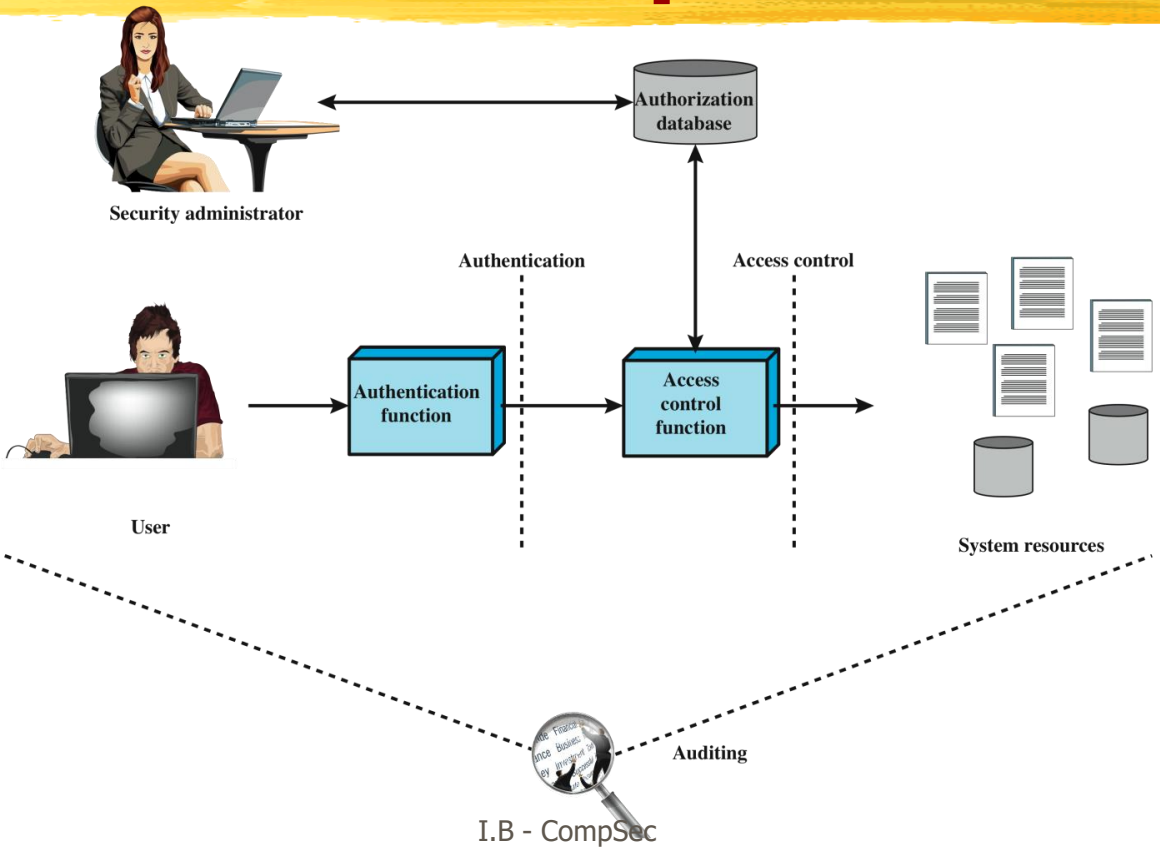
Kerberos - Overview



Kerberos Realms



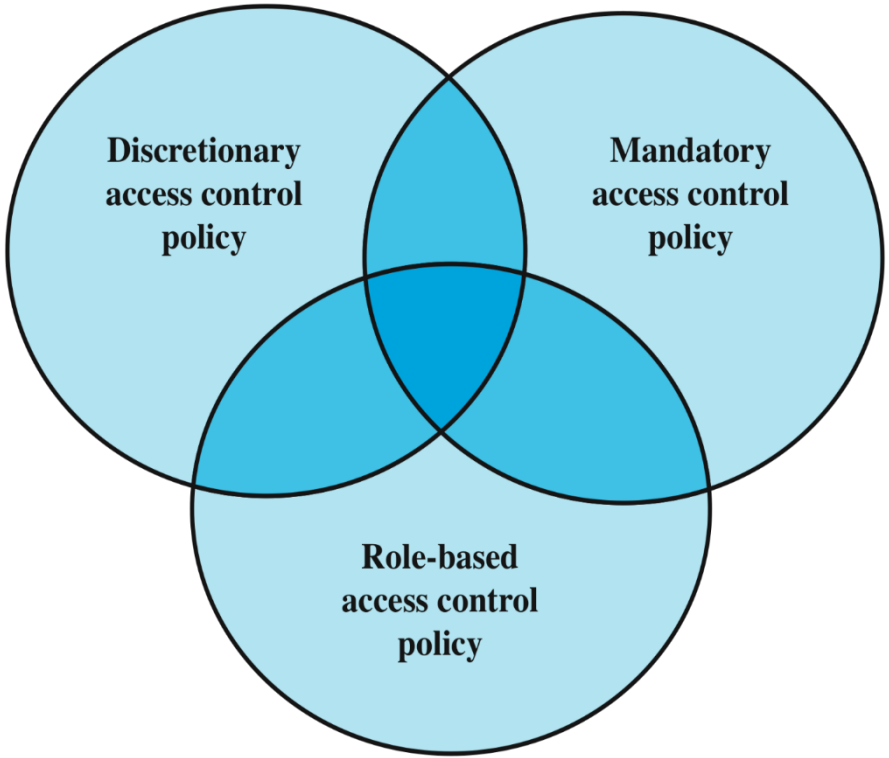
Access Control Principles



Multiple Access Control Policies

DAC

Entity can enable another entity to access some resources



MAC

Entity cannot enable another entity to access some resources

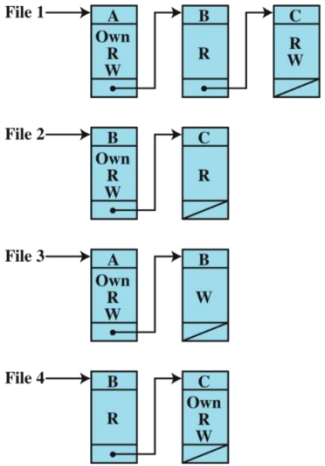
RBAC -(Roles and rules defined in the sytem controls the access

DAC, Access Matrix, ACLs C-Lists

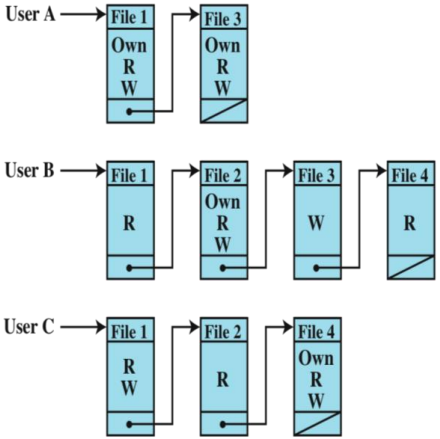
- (b) ACLs = Access Control Lists
  - Per columns = per object
- (c) Capability list (ticket)
  - Per row= per subject (user\system)
  - Can also contain default\public entry

	OBJECTS			
	File 1	File 2	File 3	File 4
User A	Own Read Write		Own Read Write	
User B	Read	Own Read Write	Write	Read
User C	Read Write	Read		Own Read Write

(a) Access matrix



(b) Access control lists for files of part (a)



(c) Capability lists for files of part (a)

RBAC - Access Control Matrix

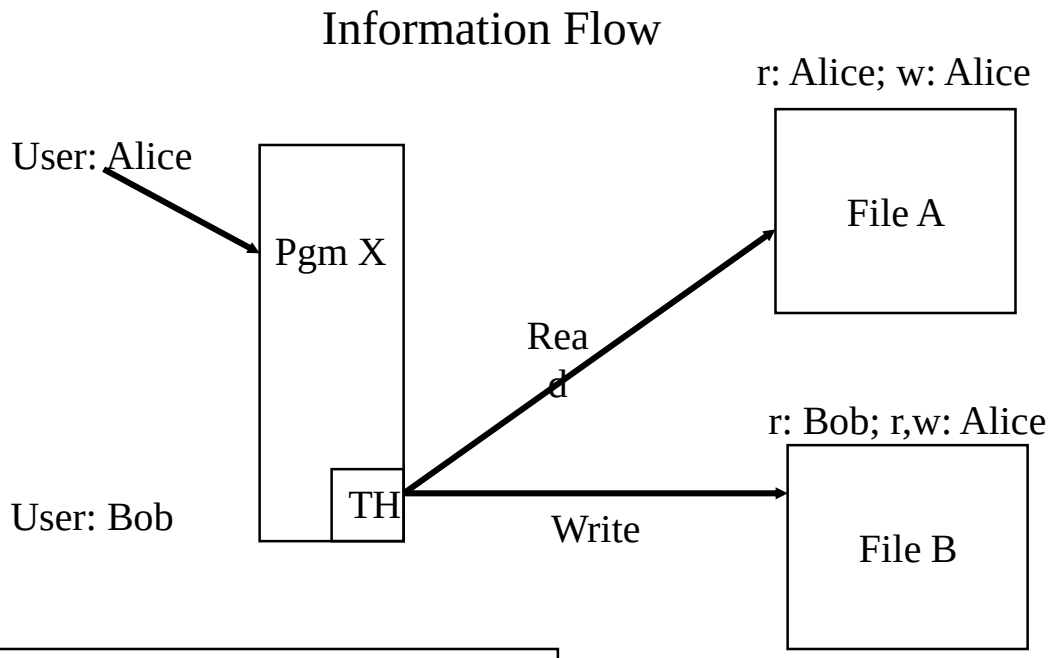
	R_1	R_2	...	R_n
U_1	X			
U_2	X			
U_3		X		X
U_4				X
U_5				X
U_6				X
...				
U_m	X			

- Assigning Users to Roles:
  - More Users than Roles
  - User Can be assigned to multiple roles
  - Roles can b e assigned to multiple users

- Assigning Roles to Objects:
  - More Objects than Roles
  - Role can be treated as an object – for role hierarchies definition.

ROLES \ OBJECTS	R_1	R_2	R_n	F_1	F_1	P_1	P_2	D_1	D_2
R_1	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
R_2		control		write *	execute			owner	seek *
...									
R_n			control		write	stop			

The Information Flow Problem of DAC (II)



User Bob can read contents of the file A copied to file B

Bell-LaPadula (BLP) Confidentiality Model (1973)

- By David Bell and Leonard LaPadula
- Hierarchical
- Addresses the confidentiality of information in a system
- Mandatory access control
- Formalize the U.S. Department of Defense (DoD) multilevel security (MLS) policy; the basis for the Orange Book
- Simple security property – read capability only
  - A subject can read information at or below his level of secrecy, but cannot read any information above his level of secrecy (no read up)
- Star property – write capability only
  - A subject can write information at or above his level of secrecy, but cannot read any information above his level of secrecy (no write down)

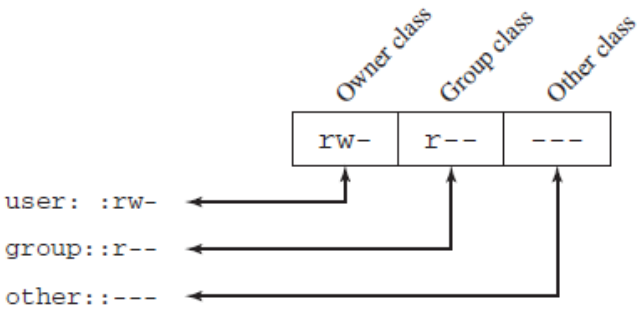
Problems of BLP

1. The need for a Trusted subject (to write non-secret info.)

Solution: **high watermark**! – get the sensitivity level of the highest level accessed object during the program execution so far…

2. The problem of covert channels.
3. No access-control when all subjects and all objects are at the same level.

Example: UNIX File Access Control



(a) Traditional UNIX approach (minimal access control list)

- Inode (Index node) = control structure needed for OS for particular file. Contains:
- Each user has unique user identification number (user ID)
- Each user is a member of a primary group identified by a group ID
- Each user belongs to a specific group
- 12 protection bits
  - specify read, write, and execute permission for the owner of the file, members of the group and all other users
- First 9 bits include authorization to USER,GROUP and other.
- the owner ID, group ID, and protection bits are part of the file's inode

Traditional UNIX File Access Control

- Last 3 bits, specify additional behaviors:

- "set user ID"(SetUID) / "set group ID"(SetGID)
  - system temporarily uses rights of the file owner / group in addition to the real user's rights when making access control decisions
  - enables privileged programs to access files / resources not generally accessible

- sticky bit
  - when applied to a directory it specifies that only the owner of any file in the directory can rename, move, or delete that file

- superuser
  - is exempt from usual access control restrictions
  - has system-wide access

Kernel vs User Space

- Kernel space
  - refers to memory used by the Linux kernel and its loadable modules (e.g., device drivers)
- User space
  - refers to memory used by all other processes
- since kernel enforces Linux DAC and security critical to isolate kernel from user
  - so kernel space never swapped to disk
  - only root may load and unload kernel modules

Linux System Hardening

- consider how to mitigate Linux security risks at system and application levels
- first look at OS-level security tools and techniques that protect the entire system

OS Installation

- security begins with O/S installation
- especially what software is run
  - since unused applications liable to be left in default, un-hardened and un-patched state
- generally should not run:
  - X Window system, RPC services, R-services, inetd, SMTP daemons, telnet etc
- also have some initial system s/w configuration:
  - setting root password
  - creating a non-root user account
  - setting an overall system security level (usually initial file-permission settings)
  - enabling a simple host-based firewall policy
  - Using extended ACLs
  - enabling SELinux (Mandatory access control)

Windows Access Control

- Access control in Windows applies to objects: files, registry keys, Active Directory objects,…
- More complex than access control in a file system.
- Access rights beyond read and write.

- two forms of access control list (ACL):
- Discretionary ACL (DACL)
  - grants or denies access to protected resources such as files, shared memory, named pipes etc
- System ACL (SACL)
  - used for auditing and to enforce mandatory integrity policy

Security Descriptor (SD)

- data structure with object owner, DACL, & SACL
  - e.g.

```
Owner: CORP\Blake
ACE[0]: Allow CORP\Paige Full Control
ACE[1]: Allow Administrators Full Control
ACE[2]: Allow CORP\Cheryl Read, Write and Delete
```

- have no implied access, if there is no ACE for requesting user, then access is denied
- applications must request correct type of access
  - if just request "all access" when need less (e.g. read) some user's who should have access will be denied

Windows System Hardening

- process of shoring up defenses, reducing exposed functionality, disabling features
  - known as attack surface reduction
  - use 80/20 rule on features
  - not always achievable
  - e.g. requiring RPC authentication in XP SP2
  - e.g. strip mobile code support on servers
- servers easier to harden:
  1. are used for very specific and controlled purposes
  2. perceive server users are administrators with better computer configuration skills than typical users

Vulnerabilities

חולשות

- בכל מערכת (תוכנה או חומרה) קיימות חולשות (נקודות תורפה, חורי אבטחה)
- יצרניות מערכות תוכנה/תוכנה-חומרה, כמו גם חוקרים מקהיליית האבטחה, מחפשים באופן תמידי אחר נקודות תורפה במערכות
  - לדוגמא: מיקרוסופט התחייבה לפרסם מידע על נקודת התורפה, תוך 90 יום מזמן שנודע לה עליה
  - כיום מפרסמת מיקרוסופט פעם בחודש (patch Tuesday) תיאור של חורי האבטחה, ותיקונים (Patches) עבורם
- מירב נקודות התורפה הן תוצאה של באגים בתכנות או בתכנון
- חלק הארי נובע מחוסר בדיקות תקינות של מספר, תחום ואורך של פרמטרים, אג תהגה מחוצצים

Exploits – התקפות

- התקפות (Exploits) שמנצלות חורי אבטחה (Vulnerabilities) יכולות להיות מקומיות או מרוחקות:
  - Local Exploits – התקפות שמחייבות גישה אל המערכת (משמע שבכדי להפעיל אותן צריך להיות משתמש לגיטימי של המערכת)
  - Remote Exploits – התקפות שניתן להפעילן "מרחוק", מבלי להיות משתמש של המערכת

- בעידן האינטרנט חור אבטחה שניתן לניצול מרחוק, הוא יותר קריטי מחור אבטחה שניתן רק לניצול מקומי

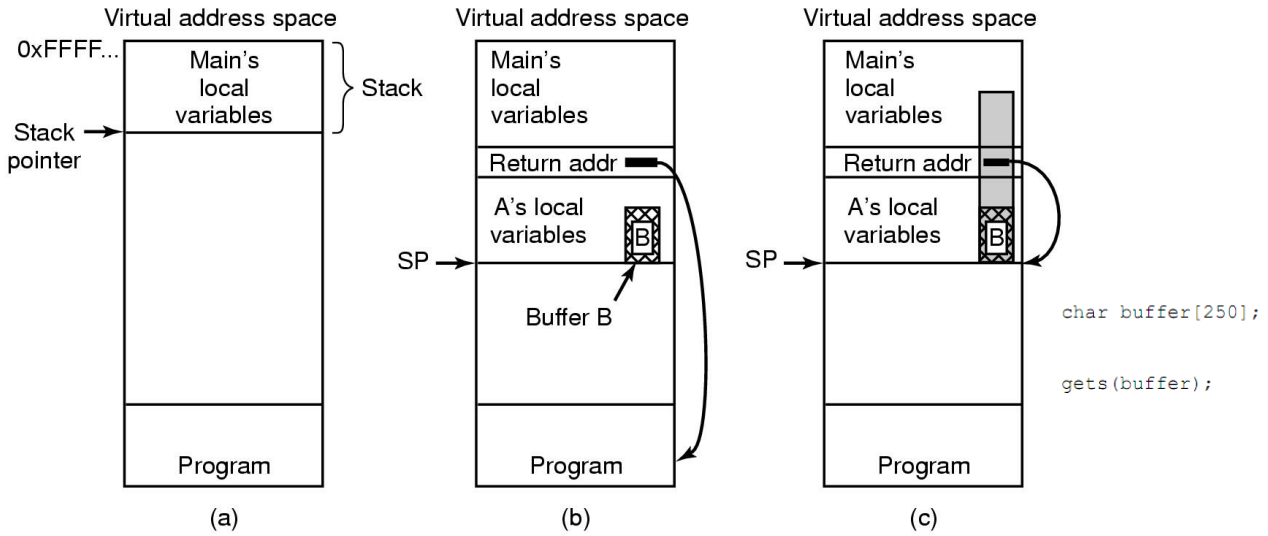
חולשות והתקפות Zero-Day

- מירב ההתקפות (וירוסים, תולעים) הגדולות ניצלו חורי אבטחה, שפורסמו עבורם תיקונים (patches)
- מירב כלי ההגנה מתגוננים כנגד התקפות ידועות, או התקפות שמנצלות חורי אבטחה ידועים
  - למשל Anti-Virus
  - למשל IPS (Intrusion Prevention Systems)
- התקפה או חור אבטחה שטרם התפרסם עבורם תיקון (patch) נקראים Zero-day attack
  - או Zero-day vulnerability

חולשות אבטחה

- חולשות אבטחה נובעות ממגוון רחב של סיבות
  - תכנות שאינו עומד בדרישות רגילות של הנדסת תוכנה
    - למשל, חוסר בדיקת חריגה ממערכים או מתחום קלט חוקי
  - הנחות שאינן מתקיימות
    - למשל, תוקף יכול לשנות תוכן של קובץ שהתכנית משתמשת בו
  - הנדסה חברתית
    - תוקף יכול פשוט לבקש את הסיסמא ("בבקשה")
  - מנשק למשתמש מבלבל
    - תצוגה לא מלאה של נתונים, או פקודה לא ברורה
  - ועוד
- הפתרון הכי טוב הוא פשוט להיות מודע
  - ולפתח בהתאם
  - לעיתים זה דורש יותר עבודה, או קוד יותר מסובך
  - אבל לפעמים זה אפילו יותר פשוט

Vulnerabilities – Buffer Overflow



- (a) Situation when main program is running
- (b) After program *A* called
- (c) Buffer overflow shown in gray

BO Defenses

- Safe coding
- Canary
- NX / DEP / XD
  - prevent code executing in data segments
- Stack Randomization
- Image Randomization (ASLR)
  - makes O/S less predictable for attackers
- Service Restart Policy (Windows)

Vulnerabilities – Others

- OWASP (The Open Web Application Security Project) Top 10
  - XSS, SQLI,…
- Others
  - CSRF
  - ROP
  - Row hammer, Spectre/Meltdown

Malicious code

- *Viruses* – A virus is a program that attaches itself to another program, propagates, and usually causes some data destruction.
  - Discussed virus-antivirus coevolution
  - Detection strategies

- *Worms*—A worm is a program that propagates itself without infecting the host.
  - Discussed knows worms: Morris, Code-Red, Slammer, Stuxnet
  - Scanning strategies

- *Trojan Horses*—A Trojan Horse is an apparently useful program that has hidden functions, usually harmful.

מודל רשת ה- Internet

Application
TCP (תובלה)
IP (רשת)
MAC (פיזית)

בשל המורכבות העבודה מתחלקת בין שכבות.

כל שכבה מתקשרת פיזית עם השכבות הסמוכות לה, ולוגית עם השכבה המקבילה לה.

מודל רשת ה-Internet

מושגים במודל שצריך להכיר (רשימה חלקית):

TCP – Connection oriented, Reliable

UDP – Connectionless, Unreliable

TCP 3-way handshake (SYN, SYN-ACK, ACK)

Gateways

Ports

Sockets

התקפות ב-Internet

- Sniffing
- Syn Attack
- DNS Poisoning
- IP Spoofing
- Port scan
- זיהוי אפליקציות רצות על השרת
- ...

הגנות ברשת

- ניתן לסווג את בעיות האבטחה לשני תתי-סוגים:
  - בעיות הנובעות מחשיפת המחשב לעולם
  - בעיות הנובעות מארכיטקטורת הרשת (מודל השכבות)

- לפיכך, ניתן לדבר על שני סוגי הגנה:
- Firewalls/IDS/IPS- לצמצום החשיפה לעולם
- פרוטוקולי אבטחה- להגנה על כל שכבה בנפרד

Firewall

- ניתן לחלק לשלשה סוגים:
  - Packet Filter (stateless)- מסנן את החבילות לפי כללים סטאטיים
  - Stateful PF- משתמש בכללים דינאמיים העוקבים אחרי מצב ההתקשרות
  - Proxy servers- התערבות אקטיבית בין המשתמש לשרת המרוחק

Security Intrusion & Detection

Security Intrusion

a security event, or combination of multiple security events, that constitutes a security incident in which an intruder gains, or attempts to gain, access to a system (or system resource) without having authorization to do so.

Intrusion Detection

a security service that monitors and analyzes system events for the purpose of finding, and providing real-time or near real-time warning of attempts to access system resources in an unauthorized manner.

Intrusion Detection Systems

- classify intrusion detection systems (IDSs) as:
  - Host-based IDS: monitor single host activity
  - Network-based IDS: monitor network traffic
- logical components:
  - sensors - collect data
  - analyzers - determine if intrusion has occurred
  - user interface - manage / direct / view IDS

Intrusion Prevention Systems (IPS)

- recent addition to security products which
  - inline net/host-based IDS that can block traffic
  - functional addition to firewall that adds IDS capabilities
- can block traffic like a firewall
- using IDS algorithms
- may be network or host based

פרוטוקולי אבטחה

Application
TCP (תובלה)
IPsec
IP (רשת)
MAC (פיזית)

באיזו שכבה להוסיף שירותי אבטחה?

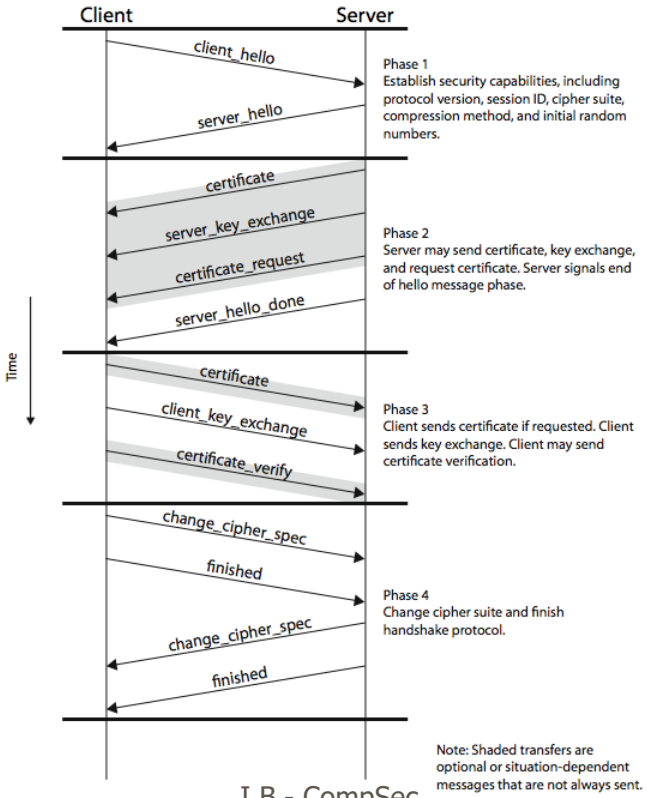
הגדרה: נאמר שפרוטוקול אבטחה עובד ברמה x אם הוא מגן על המידע של השכבות שמעל x.
לדוגמא, הוספת הגנה ברמת הרשת:

IPSec- אבטחה ברמת הרשת

- IPSec מכיל את הפרוטוקולים הבאים
  - שני פרוטוקולים לאבטחת תעבורת IP:
    - ESP – מספק הצפנה ו/או אימות
    - AH – מספק אימות בלבד
  - פרוטוקול לניהול והחלפת מפתחות IKE.
- ניתן להשתמש ב-IPSec בשני אופנים:

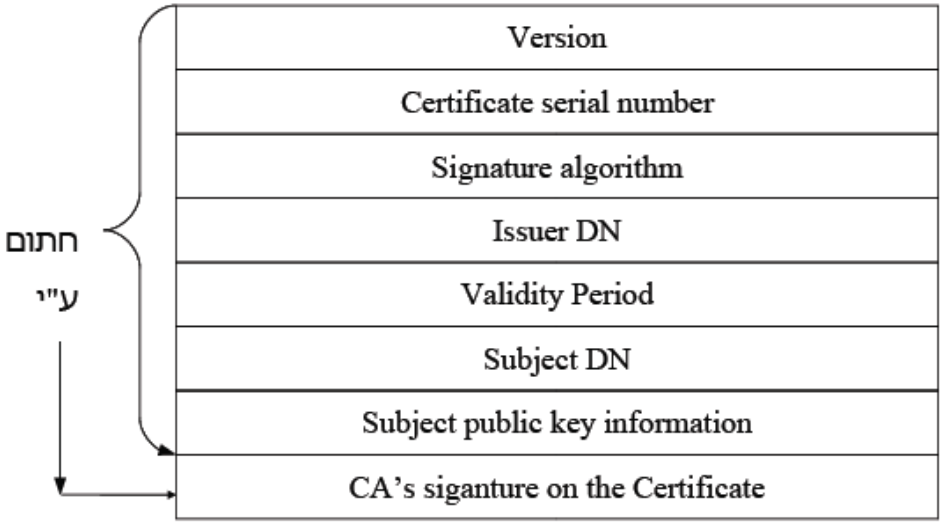
- Transport Mode - בין מחשבי קצה
- Tunnel Mode - באופן שקוף למשתמש (למשל ליצירת VPN)

SSL Handshake Protocol



אבטחה ברמת האפליקציה

X.509v3 Certificate Format



PGP- דוגמה למחזיק מפתחות

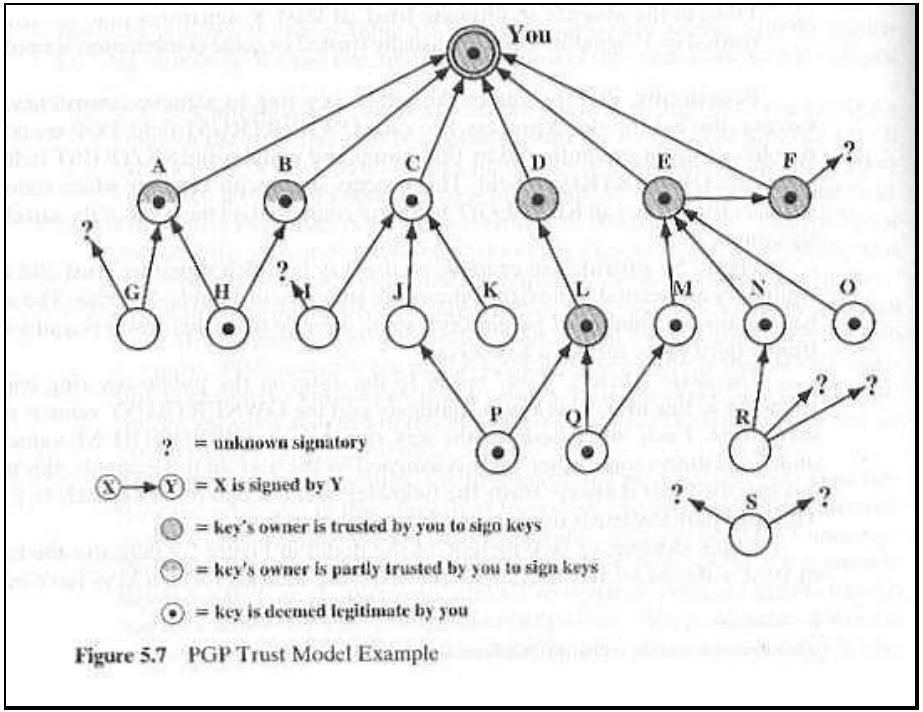


Figure 5.7 PGP Trust Model Example

נושאי העשרה

- ביטקוין
  - בלוקצ'יין
  - כרייה

- השפעת מיחשוב קוואנטי על הצפנה
  - פירוק לגורמים
  - הצפנות חסינות קוואנטום
  - הצפנה קוואנטית